(붙임 1)

자체 보안성 검토 개요

1. 업무명 : 『 AI OCR 계좌정보 입력 지원 서비스 』

○ **자체 보안성 검토 근거**

※ 본 건은 당행 이용자를 대상으로 하는 자체 보안성심의 대상 외 IT업무에 대한 신기술 도입 건으로 「자체 보안성 검토·심의 운영서 제5장 제21조(자체 보안성검토 대상) 1항」에 의거하여 자체 보안성 검토를 실시함.

- 제5장, 제21조, 1항 : **자체 보안성심의 대상 외 IT 업무에 대한 신기술 도입 등으로 보안성 검토가 필요하여 IT 부서로부터 보안 대책 적정성에 대한 검토를 의뢰 받은 경우**

2. 적용 예정일: 2026년 6월 예정

- AI거버넌스 검토 대상으로 거버넌스 승인 일정에 따라 진행
  * AI 거버넌스는 AX추진부와 별도 진행 예정

3. 업무 개요

가. 추진 배경

- 디지털 뱅킹 계좌 이체 편의성 극대화를 통해 고객 경험(CX) 제고
- AI OCR을 활용한 송금 절차 간소화를 통해 은행 디지털 채널 경쟁력 강화

나. 서비스 개요

- iM뱅크 앱에서 고객이 촬영하거나 앨범에서 선택한 이미지 내 계좌정보를 AI OCR로 인식하고, 인식된 계좌 중 고객이 선택한 계좌로 송금 정보를 자동 입력해주는 서비스

다. 대상 채널:

- iM뱅크 앱(IOS/Android)

라. 대상 업무

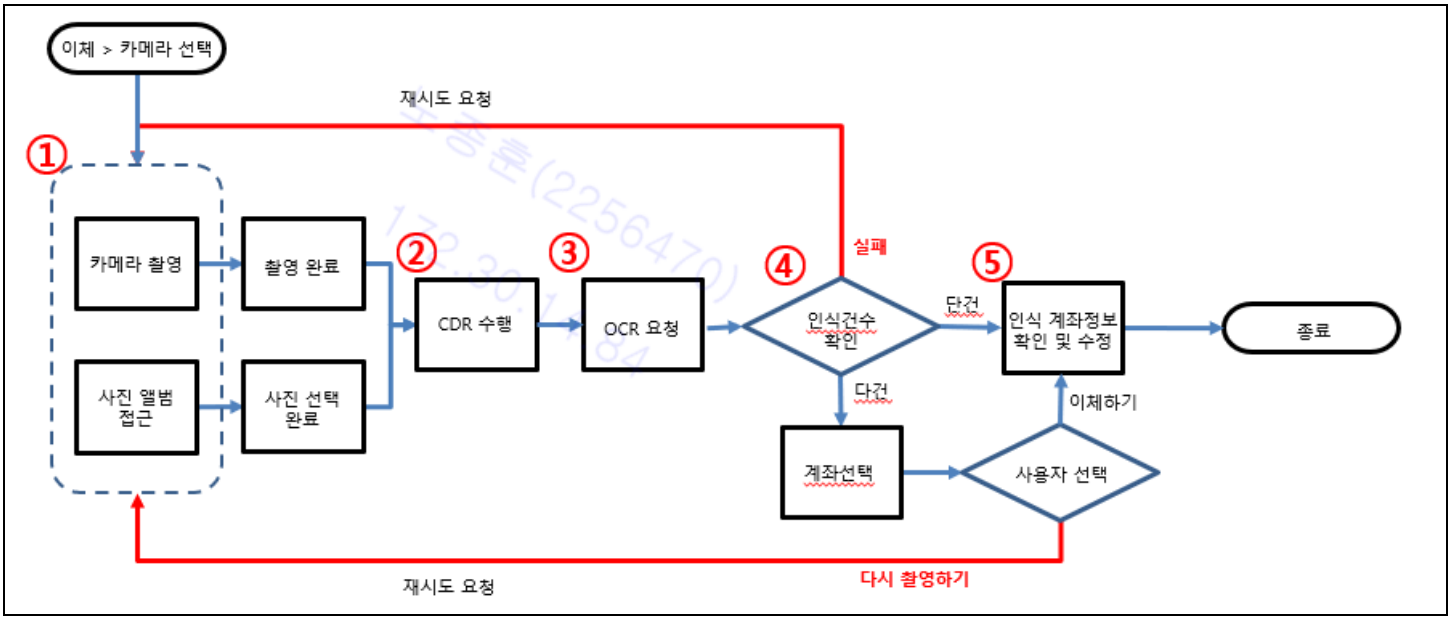
- 당행 iM뱅크 앱 내에서 운영되는 AI OCR 계좌정보 입력 지원 서비스

마. 업무 제공 시간: 24시간 365일

4. 업무처리 절차

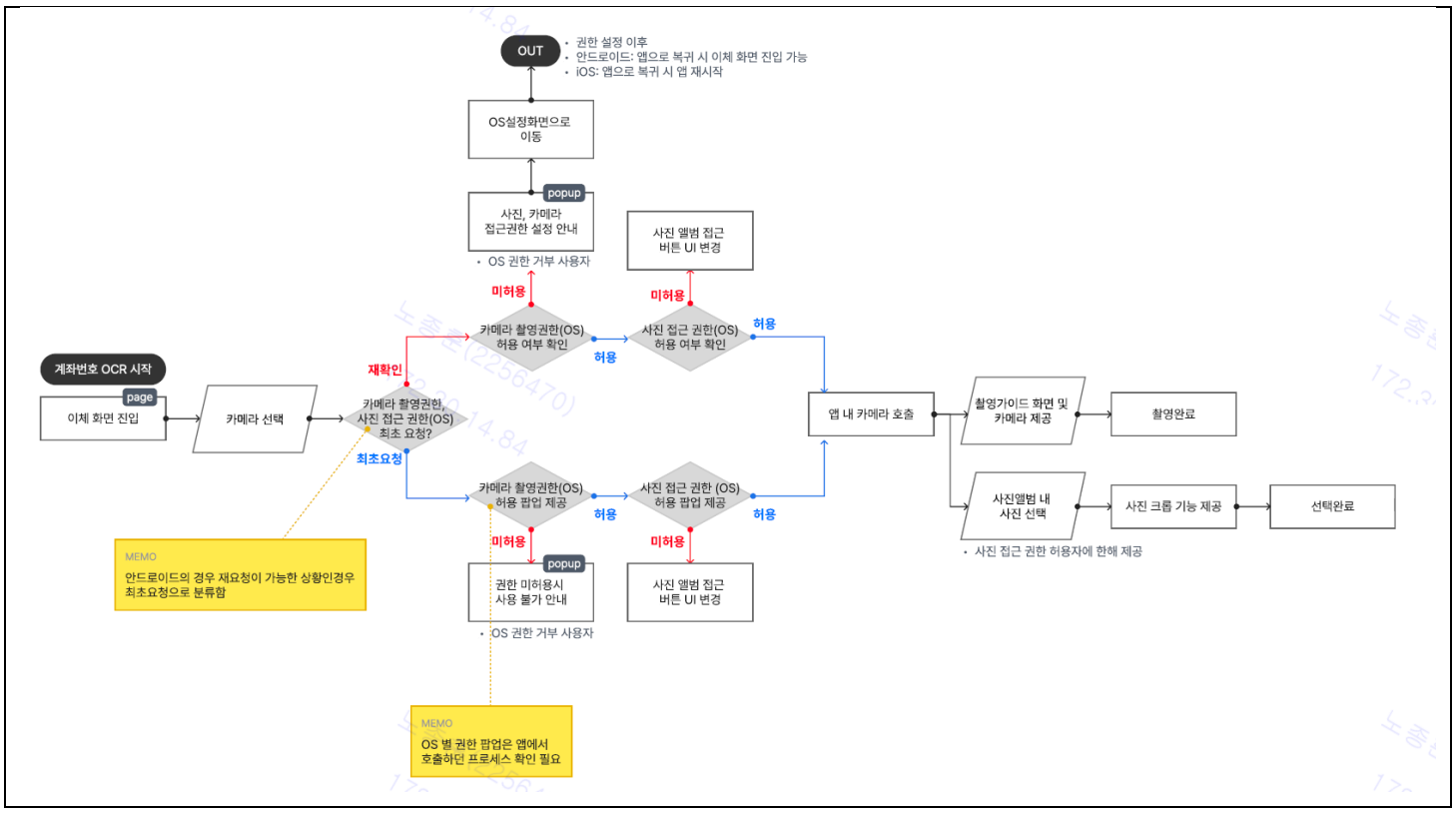
가. 주요업무 서비스 흐름도

(1) 주요 업무 흐름도

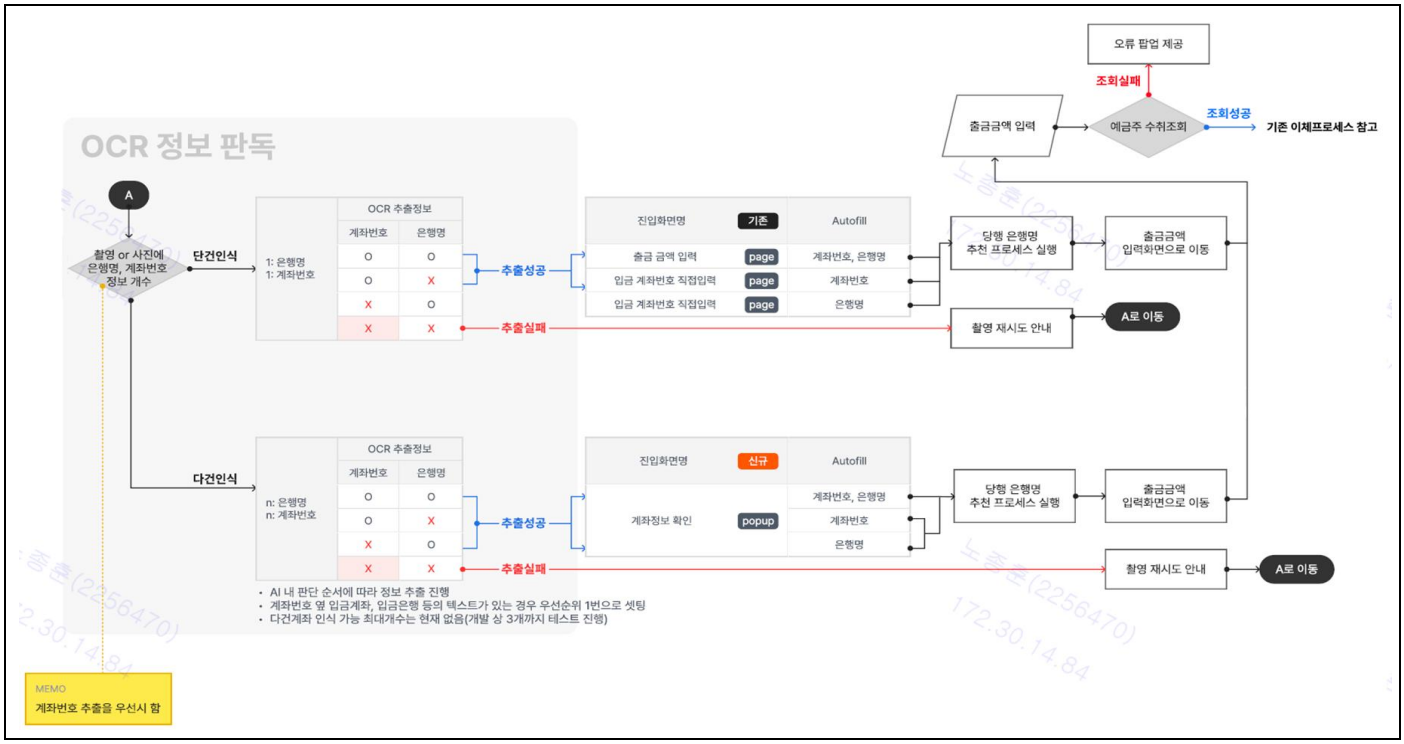


번호	절 차	주 요 내 용
①	**이미지 선택**	- 고객은 카메라 촬영과 앨범 내 이미지 중 선택하여 OCR 수행
②	**CDR 수행**	- ①에서 선택한 이미지를 CDR 솔루션을 통해 콘텐츠 무해화 작업 수행
③	**OCR 요청**	- 무해화 처리된 이미지로 OCR 요청
④	**인식 건수 확인**	- **단건인식** 1) 계좌번호 & 은행명 존재 - 입금 계좌번호 입력 화면 이동 후 OCR 추출정보 자동 기입 2) 계좌번호 또는 은행명만 존재 - 입금 계좌번호 입력 화면 이동 후 OCR 추출정보 자동 기입 3) 추출 실패 - 촬영 재시도 요청 - **다건인식** 1) 인식된 계좌정보 리스트 팝업 노출 후 사용자 선택에 따라 단건인식과 동일한 프로세스 수행
⑤	**인식 정보 확인**	- 자동으로 입력된 정보를 고객이 확인 후 수정하거나 기존 이체 프로세스 진행

(2) AI 사진송금 서비스 OCR 요청 상세 프로세스

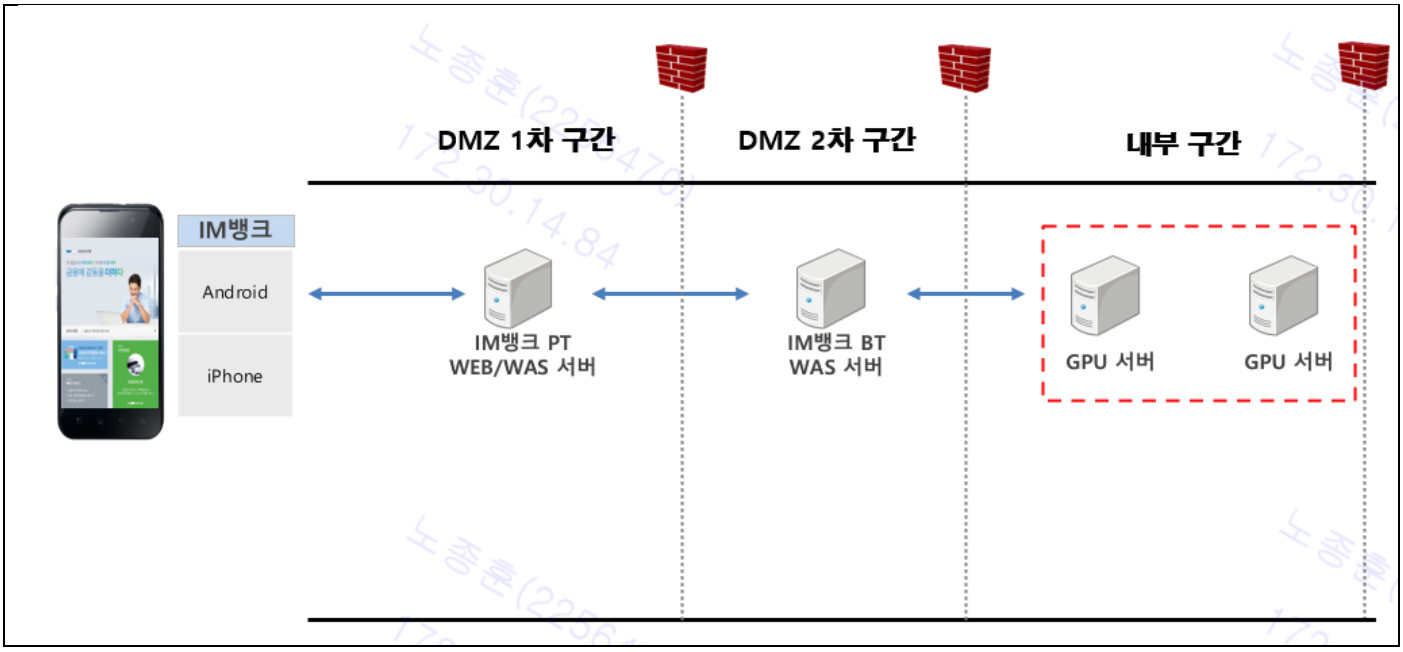


(3) OCR 결과에 따른 상세 프로세스

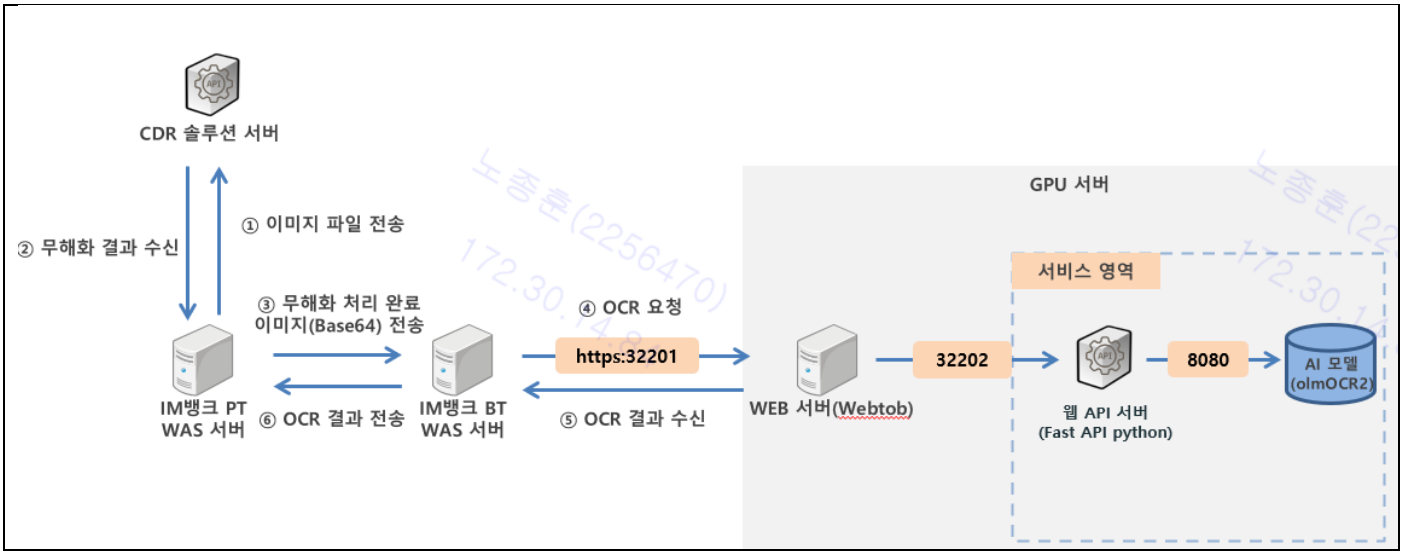


나. 서비스 시스템 구성

(1) 시스템 구성도



(2) AI OCR 프로세스 구성도



5. 주요업무 거래 시 보안 절차

가. 파일 처리

(1) 앱 내 카메라/갤러리 호출 기능의 응답 포맷은 '이미지 포맷'으로 앱 내에서 이미지 압축 및 크롭 기능 수행 시 '이미지 포맷'이 아닌 경우 실패하도록 구현

(2) 이미지 압축/크롭 시 파일 최대 크기는 1MB, 해상도는 최대 500x500 적용 후 JPG 파일로 생성

(3) 뱅킹 서버는 JPG 시그니처 검증 수행하여 JPG 확장자만 허용하도록 구현

(4) OCR 프로세스 수행과정 중 서버 내 파일 저장은 수행하지 않고, 메모리에서 처리가 이루어지며 처리 후 메모리 해제

나. 이미지 내 악성코드 처리

(1) 고객이 전달한 이미지는 CDR(컨텐츠 무해화) 솔루션으로 악성코드 및 액티브 컨텐츠 제거된 상태로 OCR 프로세스 수행

다. 프롬프트 인젝션

(1) OCR 수행 직전 고정된 프롬프트로 요청하며 시스템 프롬프트와 OCR 요청부를 명확히 분리하여 프롬프트 인젝션 방지

(2) 이미지 내 프롬프트 인젝션 존재 시 '라. 응답 메시지 검증 처리'에 따라 응답 통제

라. 응답 메시지 검증 처리

(1) 응답정보는 서버에서 검증 및 고정 항목(계좌번호, 은행정보)만 응답하도록 설계

- 계좌번호 : 계좌번호 포맷(8~16자리) 검증
- 은행명 : 사전에 정의된 데이터셋 내에서만 응답하도록 검증

(2) 주민등록번호 패턴은(13자리) 정규식 적용하여 응답에서 제외

마. 타인 응답정보 유출

(1) 요청 간 정보가 공유되지 않도록 요청마다 세션을 분리하며, 추론 캐시를 요청 단위로 초기화하여 응답정보 유출 방지

바. 인증 방식

(1) 모바일앱 뱅킹 로그인 : 간편비밀번호 로그인, 패턴, 지문, 얼굴인증, 금융인증서, 공동인증서 및 ID에 기반하여 로그인 수행

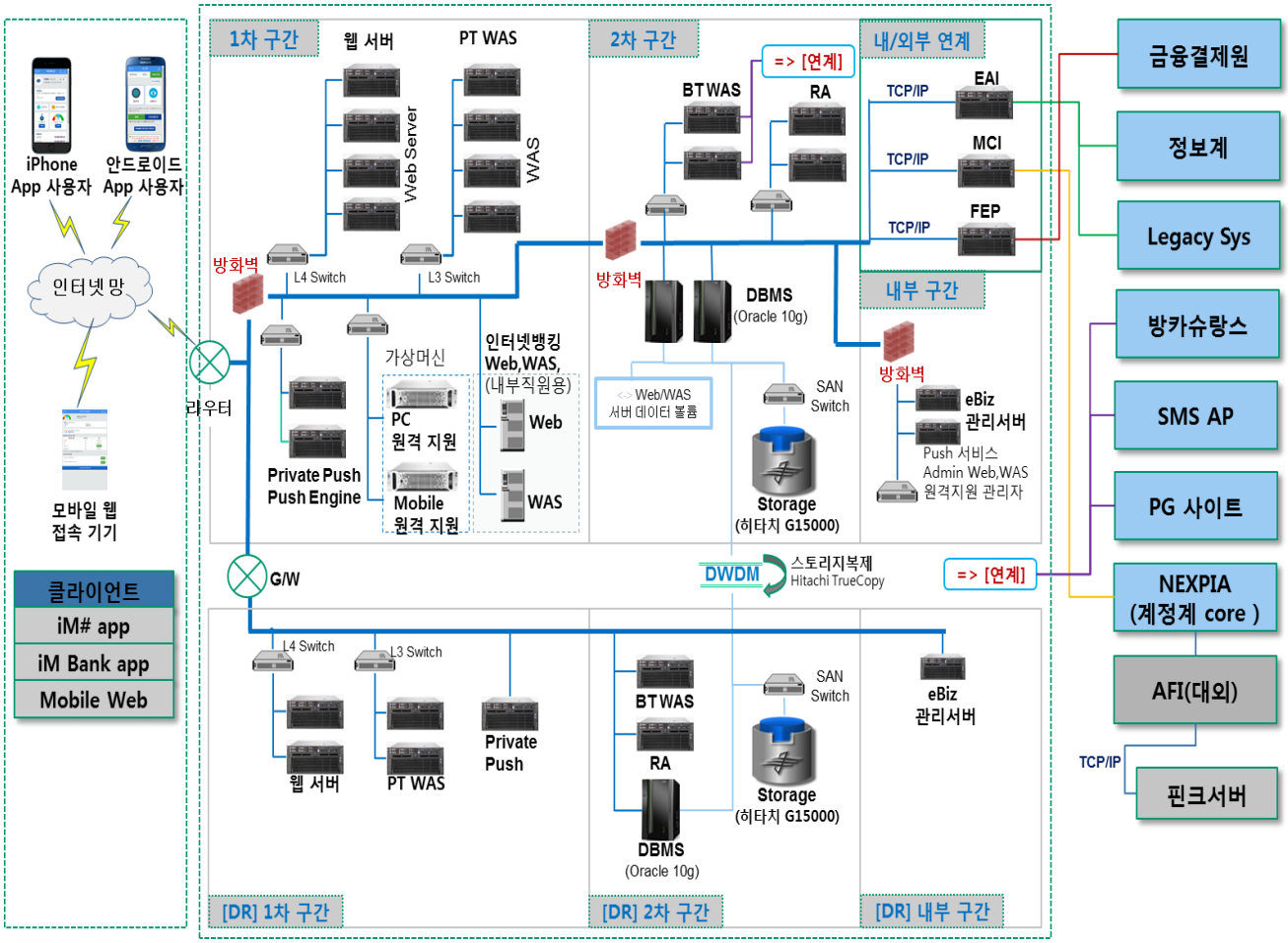
6. 시스템 구성

가. 개요

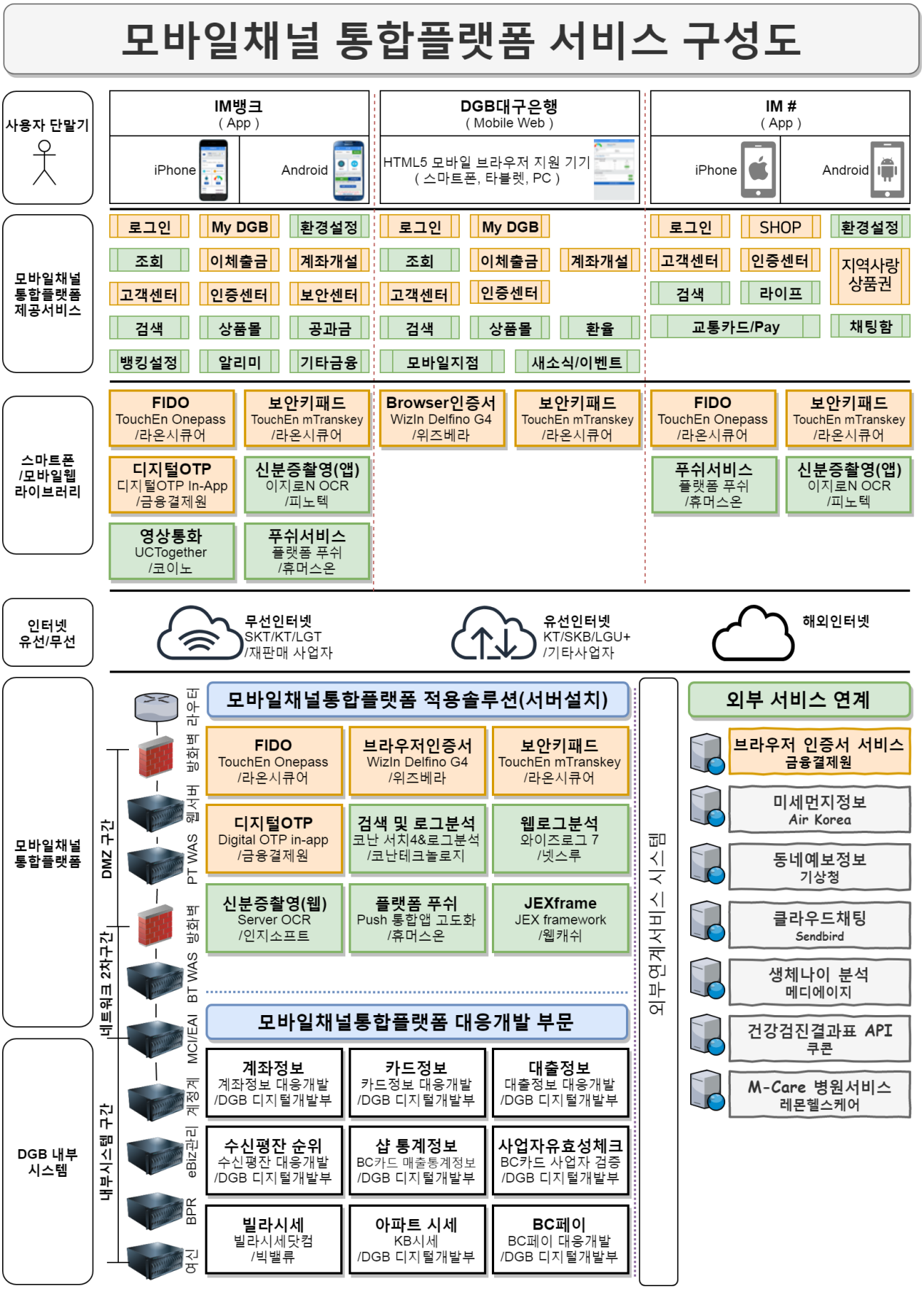
(1) 본건 심의 대상의 서비스 및 솔루션은 기존 스마트 뱅킹(모바일웹) 시스템의 인프라 활용

(2) 관련 보안솔루션 종류로는 기존 스마트뱅킹 (모바일웹)에서 사용하고 있는 TouchEn mTransKey(키보드 보안), 검색 및 사용자 행위 로그 분석을 위하여 Konan Search4 및 WiseLog 솔루션을 활용함

나. 전체 시스템 구성도

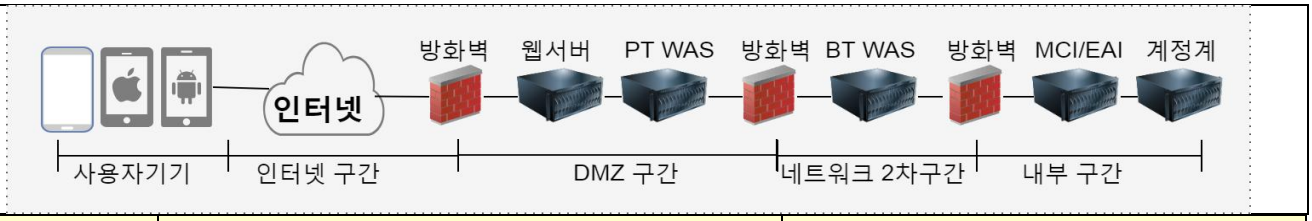


다. 서비스 구성도


모바일채널 통합플랫폼 서비스 구성도
사용자 단말기
IM뱅크
(App)
iPhone
Android
DGB대구은행
(Mobile Web)
HTML5 모바일 브라우저 지원 기기
(스마트폰, 타블렛, PC)
IM #
(App)
iPhone
Android
모바일채널 통합플랫폼 제공서비스
로그인
My DGB
환경설정
조회
이체출금
계좌개설
고객센터
인증센터
보안센터
검색
상품몰
공과금
뱅킹설정
알리미
기타금융
로그인
My DGB
조회
이체출금
계좌개설
고객센터
인증센터
검색
상품몰
환율
모바일지점
새소식/이벤트
로그인
SHOP
환경설정
고객센터
인증센터
지역사랑 상품권
검색
라이프
교통카드/Pay
채팅함
스마트폰 /모바일웹 라이브러리
FIDO
TouchEn Onepass
/라온시큐어
보안키패드
TouchEn mTranskey
/라온시큐어
디지털OTP
디지털OTP In-App
/금융결제원
신분증촬영(앱)
이지로N OCR
/피노텍
영상통화
UCTogether
/코이노
푸쉬서비스
플랫폼 푸쉬
/휴머스온
Browser인증서
WizIn Delfino G4
/위즈베라
보안키패드
TouchEn mTranskey
/라온시큐어
FIDO
TouchEn Onepass
/라온시큐어
보안키패드
TouchEn mTranskey
/라온시큐어
푸쉬서비스
플랫폼 푸쉬
/휴머스온
신분증촬영(앱)
이지로N OCR
/피노텍
인터넷 유선/무선
무선인터넷
SKT/KT/LGT
/재판매 사업자
유선인터넷
KT/SKB/LGU+
/기타사업자
해외인터넷
모바일채널 통합플랫폼
DMZ 구간
네트워크 2차구간
내부시스템 구간
라우터
방화벽
웹서버
PT WAS
방화벽
BT WAS
MCI/EAI
계정계
eBiz관리
BPR
여신
모바일채널통합플랫폼 적용솔루션(서버설치)
FIDO
TouchEn Onepass
/라온시큐어
브라우저인증서
WizIn Delfino G4
/위즈베라
보안키패드
TouchEn mTranskey
/라온시큐어
디지털OTP
Digital OTP in-app
/금융결제원
검색 및 로그분석
코난 서치4&로그분석
/코난테크놀로지
웹로그분석
와이즈로그 7
/넷스루
신분증촬영(웹)
Server OCR
/인지소프트
플랫폼 푸쉬
Push 통합앱 고도화
/휴머스온
JEXframe
JEX framework
/웹캐쉬
모바일채널통합플랫폼 대응개발 부문
계좌정보
계좌정보 대응개발
/DGB 디지털개발부
카드정보
카드정보 대응개발
/DGB 디지털개발부
대출정보
대출정보 대응개발
/DGB 디지털개발부
수신평잔 순위
수신평잔 대응개발
/DGB 디지털개발부
샵 통계정보
BC카드 매출통계정보
/DGB 디지털개발부
사업자유효성체크
BC카드 사업자 검증
/DGB 디지털개발부
빌라시세
빌라시세닷컴
/빅밸류
아파트 시세
KB시세
/DGB 디지털개발부
BC페이
BC페이 대응개발
/DGB 디지털개발부
DGB 내부 시스템
외부연계서비스 시스템
외부 서비스 연계
브라우저 인증서 서비스
금융결제원
미세먼지정보
Air Korea
동네예보정보
기상청
클라우드채팅
Sendbird
생체나이 분석
메디에이지
건강검진결과표 API
쿠콘
M-Care 병원서비스
레몬헬스케어

7. 기술적 보안대책

가. 보안구성도



구 분	보안 취약점 및 요건	대 책
사용자 기기	- 인증/부인방지 - 사용자 정보 보호	- 공인인증서 - 데이터 암호화 - 가상 키패드 - 증명서위변조
네트워크 구간	- 거래 내용의 기밀성 및 무결성	- 구간 암호화 (SSL 인증서) - 메시지인증코드(MAC)
DMZ구간	- 사용자 신분확인 - 시스템 접근 제어 - 시스템 가용성	- 공인인증서, 보안카드 또는 OTP 인증 - 방화벽 - 통합 보안관리 서버 - 침입 탐지 시스템
금융회사 내부구간	- 불필요 접근제어 - 사용자 인증 - 사용자 접근제어	- 내부 방화벽 - 서버 O/S 보안

☞ 旣 구축되어 있는 IM뱅크 인프라 활용

나. 구간별 보안취약점 및 보안대책

(1) 사용자 구간 (旣 구축된 인프라 활용)

보안 요건	보안 대책	대응 솔루션
인증/ 부인방지	- 공동인증서를 이용한 인증 및 부인방지	- 라온시큐어 TouchEn OnePass (FIDO BIO 인증서)
사용자 정보보호	- 보안카드 또는 OTP생성기를 통한 물리적 분리 - 자금이체 등 거래시 전용 휴대폰과 물리적 으로 분리관리되는 보안카드 이용 - 키보드 보안프로그램을 통한 키보드입력값 보장 - 가상키패드를 이용한 입력값 보장	- 라온시큐어 TouchEn mTranskey web (보안키패드) - 금융결제원 디지털OTP In-App
바이러스 방지	- 바이러스 검색 및 치유 - 인터넷뱅킹구간으로 전송되는 데이터 및 파일 내 바이러스 검색 - 바이러스 차단 제품 설치, 운영	- 라온시큐어 mVaccine 사용

보안 취약점	보안 대책
악성 코드 감염	- 개인 백신 솔루션 의무 설치 (라온 mVaccine) - 보안 프로그램 최신 패치

보안 취약점	보안 대책
입력정보 노출	- 인증서 비밀번호 입력필드에 가상 키보드 기본적용(라온 mTranskey) - 키입력정보에 대한 E2E 암호화 적용 - 입력정보 및 화면 출력정보 마스킹 조치
거래 비밀번호 노출 및 탈취	- 비밀번호 안전한 구성 규칙 적용 - 비밀번호 입력 오류 횟수 제한 및 횟수 초과 시 중지 - 비밀번호 재부여 시 추가 본인인증 - 가상 키패드에 입력된 정보는 암호화 처리되어 전달
메모리 내 정보 노출 및 탈취	- 메모리 해킹방지 솔루션 적용 (AppSuit)
비인가자의 불법거래	- 보안 키패드에 입력된 정보는 암호화 처리되어 전달 - 통신구간 SSL 암호화 적용
프로그램 위·변조	- 앱 위변조 방지 프로그램 적용 (AppSuit)

(2) 네트워크 구간 (旣 구축된 인프라 활용)

보안 요건	보안 대책
거래내용의 기밀성 및 무결성	- SSL 프로토콜을 사용한 거래 데이터 암호화 및 무결성 확인 - 암호화 프로토콜(SSL)을 이용하여 거래내역 노출과 거래내역 변조 방지 - X.509 v3 인증서를 이용한 암호화 키 분배 - 메시지 인증 코드 (MAC : Message Authentication Code) - 암호화된 메시지 블록에 대한 메시지 인증 코드 부여

보안 취약점	보안 대책
송수신전문 정보유출 및 변조 (중간자 가로채기 등)	- SSL 을 통한 송수신 정보, 전자금융거래 암호화 - 금융거래 시 E2E 암호화 - 세션의 사용자검증을 통한 하이재킹 차단
쿠키변조를 통한 사용자 위장	- 시큐어코딩 등을 통한 쿠키 내 중요정보 저장 금지 - 민감한 정보를 쿠키에 보관하지 않는 정책을 통해 쿠키 인젝션을 원천적으로 방지
거래 무결성 침해	- 예비거래/본거래에 거래일련번호 체크를 통해 같은 일련번호로 중복거래 시 오류 처리하여 거래무결성 제공 - 전문에 글로벌 ID 를 체크하여 이중거래 방지 - 더블클릭 방지 기능 적용

(3) DMZ구간 (旣 구축된 인프라 활용)

보안 요건	보안 대책
사용자 신분확인	- 앱로그인종류(간편/패턴/지문/금융/공동)에 따른 이용한 사용자 신분확인
시스템 접근제어	- 방화벽 설치, 운영 - 인터넷 접속망에 설치되어 패킷 필터링 수행 - 비인가자의 인터넷뱅킹 시스템의 네트웍/서버에 대한 접근 제어 - "telnet", "ftp", "rlogin"등 외부 공격에 취약한 응용서비스 차단 - 통합 보안관리 서버 운영

보안 요건	보안 대책
	- 내부 시스템 관리자 및 개발자에 대한 서버별, 사용자별 접근제어 - 시스템 관리자 권한 제어
시스템 가용성	- 침입탐지시스템 운영 - 외부로부터의 침입 감시 - 불법적인 침입탐지 시 관리자에게 경보 발송 - 불법적인 침입탐지 시 해당 세션 자동 종료 - 침입탐지시스템 설치, 운영 - 보안 점검 툴을 이용한 취약점 검색 및 보완 - 네트웍 / 서버 상의 보안취약점 검색 - 최신 해킹 기법을 이용한 주기적인 검색 - 탐지된 보안 취약점에 대한 보완책 적용 - 보안 점검 툴 설치, 운영

보안 취약점	보안 대책
사용자 권한 탈취/변조	- 거래 시 서버사이드 사용자 재인증 및 세션관리 - 앱 프로그램 무결성 검증
시스템 취약점을 이용한 해킹	- 시큐어코딩 적용 - 서비스 실시 전 모의해킹 및 취약점 분석/평가 실시
중요정보노출 및 유출	- 개인식별정보 등 중요정보 암호화 - 운영시스템 접근통제 적용 및 통제

(4) 당행 내부 구간 (旣 구축된 인프라 활용)

보안 요건	보안 대책
계정계 시스템 접근 제어	- 계정계서버 접근제어시스템 운영 및 전산원장 비밀번호 암호화 제도의 체계에 따름 - 이용자 비밀번호, 자금이체 비밀번호는 지정된 횟수 이상 오류 입력 시 사용 제한 - 모든 거래에 대한 정당성 검증 - 계정계 단말기 보안 - 책임자, 조작자 로그인 승인 제도 - 책임자 거래 승인 제도 - 본부 및 지역 본부 단말기 거래 제한 제도

(5) 임직원 구간 보안취약점 및 대책 (旣 구축된 인프라 활용)

보안 취약점	보안 대책
접속 정보유출 (중간자 가로채기 등)	- 사용자 IP 대역 별도 관리하고, 방화벽 설정을 통한 원천적 접근통제 적용
비인가자의 접근 및 시스템 이용	- 안전한 비밀번호 구성 규칙 적용 - 비밀번호 입력 오류 횟수 제한 및 횟수 초과 시 중지 - 사용자 등록은 계정관리 절차를 거쳐 승인받은 사용자만 등록, 이용 - 시스템 관리자 접근 시 서버접근통제 시스템을 적용하고, 추가인증 적용

다. 적용 보안 솔루션

구 분	적용보안솔루션	제품명	인증현황
공통	전송자료 암호화프로그램	https	SSL 인증서
안드로이드	보안키패드	라온시큐어 TouchEn mTranskey	Key#Crypto (CMVP) GS인증
	코드난독화프로그램	스틸리언 AppSuit	
	앱무결성검증	스틸리언 AppSuit	
	FIDO	라온시큐어 TouchEn OnePass	Key#Crypto (CMVP) GS인증
아이폰	보안키패드	라온시큐어 TouchEn mTranskey	Key#Crypto (CMVP) GS인증
	코드난독화프로그램	스틸리언 AppSuit	
	앱무결성검증	스틸리언 AppSuit	
	FIDO	라온시큐어 TouchEn OnePass	Key#Crypto (CMVP) GS인증

☞ 旣 구축되어 있는 스마트뱅킹(모바일 웹) 인프라 활용

8. 관리적/물리적 보안대책

가. 관리적 보안대책

○ 시스템별 관리책임자, 관리자 및 사용자 지정

○ 유지보수는 관리자 입회하에 실시하며, 최소한의 접근권한만 부여된 유지보수 계정을 통해 관리책임자 책임 하에 작업

○ 시스템 관리대장을 수기 또는 전자적으로 운용·관리

○ 정보시스템, 휴대용 저장매체, 단말기 등 반출입 통제

나. 물리적 보안대책

○ 통제구역으로 지정된 DGB혁신센터 전산동에 정보시스템을 설치하여 비인가자의 출입 금지

○ 보호구역 출입자명부를 기록 및 유지

○ CCTV로 출입자 24시간 모니터링

○ 테스트시스템은 실업무시스템과 물리적으로 분리하여 구축·운영 등

9. 담당자

소 속	직위 성명	업무담당	전화번호	이메일
디지털개발부	프로 노종훈	IT개발담당	02-3458-8458	jhnoh@imfng.com
디지털기획부	매니저 유현서	업무담당	02-3458-8401	hyunseo.yoo@imfng.com
AX추진부	프로 김지현	AI 거버넌스 담당	02-560-8594	dgb2171080@imfng.com

정보보호부	매니저 김종민	IT정보보호팀	053-740-6814	Jm_kim@imfng.com
차세대인프라부	매니저 한상민	시스템인프라담당	053-740-2497	ha2sa16mi@imfng.com

(붙임2)

자체 보안성검토 결과

○ 보안성검토 기준별 심의 결과

본건 검토 대상의 제공 서비스 채널은 **iMBank(Android, iOS) 앱**으로 구성됨

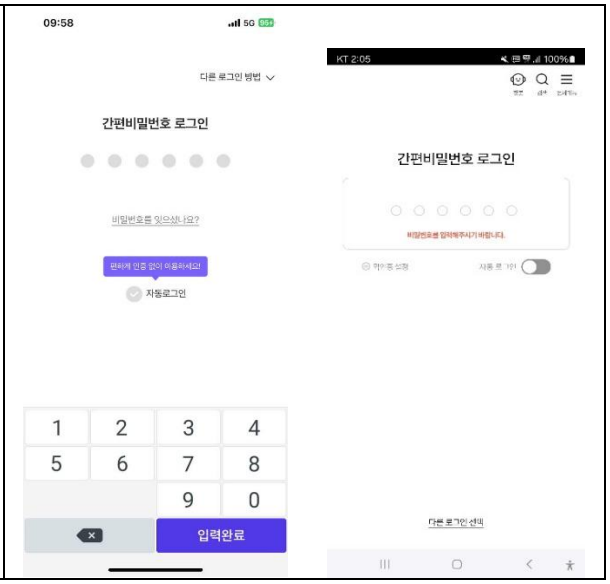
심의 기준	심의결과	비 고
거래 당사자 인증	적정	iM뱅크 - 아이디/비밀번호 인증 - 간편비밀번호 인증 - FaceID 인증 - 지문인식 인증 - 공동인증서 인증 - 금융인증서 인증
거래 정보의 기밀성 및 무결성	적정	- 통신구간 SSL 암호화 적용 - FIDO 인증(라온시큐어 TouchEn OnePass) - 보안키패드 적용(라온시큐어 TouchEn mTranskey)
정보처리시스템 보호대책	적정	- 침입차단 및 방지시스템 운영 - 24 * 365 보안관제 실시 - 정보보호시스템 운영
고객단말기 보호대책	적정	- 루팅 탐지(스틸리언 AppSuit) - 모바일백신(라온시큐어 TouchEn mVaccine) - 앱 무결성 검증(탐지시 앱 자동종료) - 실시간감시(라온시큐어 TouchEn mVaccine) - 악성코드검사(라온시큐어 TouchEn mVaccine) - 공동인증/금융인증 전자서명 보안(위즈베라 Delfino G3) - 모의해킹 및 취약점 점검 실시
정보유출방지대책	적정	- 서버 내 개인정보 검출(Server-i) - 화면 중요정보 마스킹 - 통신구간 암호화 : SSL 인증서 - 고객정보 앱 내 저장 없음
이상금융거래 방지대책	적정	- FDS 정책 운영
시스템 가용성 확보 및 비상대책	적정	- 기 인터넷뱅킹 인프라 사용으로 보안체계 준용 - 전산 장비 이중화, 데이터 이중화
시스템 설치장소에 대한 물리적 접근통제	적정	- 전산센터 보호구역 지정 - 물리적 통제 및 무선통신망 설치 통제
취약점 점검 실시	적정	- 모의해킹 및 취약점 점검 실시

※ 본건 검토 대상의 서비스 및 솔루션은 기존 iMBank인프라를 사용함으로 통신구간 및 시스템은 기 운영중인 보안정책과 동일함

Ⅰ. 보안성 심의 세부 내용

1. 거래 당사자 인증

(1) 간편비밀번호를 통한 본인 인증

- 고객 간편비밀번호 입력	

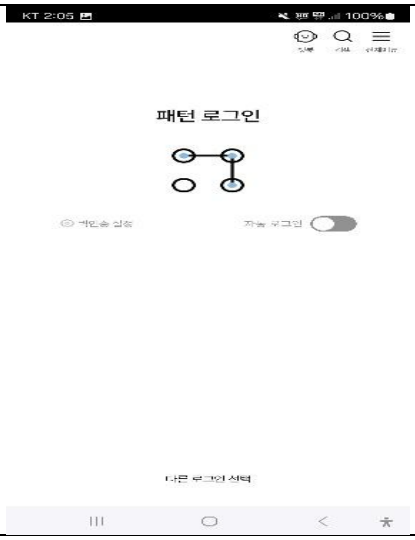
(2) Face ID를 통한 본인 인증

- 얼굴인식 진행을 통한 인증	

(3) 지문인식을 통한 본인 인증

- 지문 인식을 통한 인증	

(4) 패턴 인증을 통한 본인 인증

- 패턴 인증을 통한 인증	

(5) 공동인증서를 통한 본인 인증

- 공동인증서를 통한 인증	

(6) 금융인증서를 통한 본인 인증

- 금융인증서를 통한 인증	 KT 1:52 100% 최효선님의 금융인증서비스 인증서를 선택하세요 최효선님의 금융인증서 2026-11-09 인증서관리

2. 거래정보의 기밀성 및 무결성

(1) 통신구간 SSL 암호화 적용

통신구간 암호화는 SSL기반 및 구간 암호화로 동작하며, 업무 서버간의 거래정보 무결성을 보장함
- 고객 스마트폰에서 보이는 웹/앱 접속시 SSL 인증 적용 - SSL 프로토콜은 TCP/IP 계층과 HTTP나 IMAP 같은 상위 레벨의 프로토콜 사이에서 작동됨 - SSL은 상위 레벨 프로토콜 대신에 TCP/IP 프로토콜을 사용하여 SSL 사용 가능한 클라이언트와의 인증을 통해 SSL 사용 가능한 서버로 접속하는 것을 허가함 - 서버가 인증을 통해 클라이언트와 통신하는 것을 허가하게 되며, 이로 인해 암호화 연결이 설정된 두 개의 기계(Server, Client)가 서로 통신을 함 - SSL은 상호 인증(Mutual Authentication), 무결성(Integrity)을 위한 메시지 인증코드(MAC), 기밀성을 위한 암호화 등을 제공함으로써 클라이언트와 서버 사이에 안전한 데이터 통신을 제공함 - 이 프로토콜은 암호화, 메시지 압축, 메시지 인증코드(MAC)를 위해 이용되는 알고리즘을 선택하는 것이 가능함 - 대외 기관간 통신시 VPN을 통해 송수신

3. 정보처리시스템 보호대책

가. 침입차단 및 방지시스템 운영

○ 침입차단 및 방지시스템에 의하여 내·외부 비인가자의 접근 차단

○ 주요 업무를 수행하는 내부 서버와 업무를 중계구간 및 DMZ구간에 각각 침입차단시스템을 설치하여 외부접근이 원천적으로 차단되는 등 네트워크 분리 원칙 준수

○ 서비스에 필요한 서비스(포트)만을 허용하도록 보안정책을 적용하고, 보안정책의 변경은 정보보호 부서장의 승인 시에만 수행

○ 정보보호시스템의 원격관리 및 우회 네트워크 접속 금지

○ 전용단말기를 통한 시스템관리

○ 정보보호시스템에 대한 관리책임자 지정. 운영

나. 24*365 보안관제 실시

○ 자체 보안관제센터를 통한 24시간 365일 보안관제 및 모니터링 실시

○ 금융보안원 보안관제센터를 통한 24시간 365일 보안관제 및 모니터링 실시

다. 정보보호시스템 운영

○ 기 구축된 DDoS 공격탐지 및 대응시스템을 활용하여 DDoS 공격 발생시에도 원활하고 안정적인 서비스 제공

○ 자체 대응용량 이상의 DDoS 공격시 금융보안원 "디도스공격 비상대응센터"를 통한 원활한 서비스 제공

○ 망분리 적용 및 DB보안 시스템을 통해 DB시스템에 대한 비인가자의 접근 및 정보유출 시도 차단

○ 정기 유지보수 실시, 정보처리시스템 물리적 접근통제, 외부원격시스템 운영 금지

○ 자체 소스코드점검툴을 통한 소스코드 진단

4. 고객단말기 보호대책

기존 뱅킹 시스템의 인프라를 사용함으로 시큐어코딩, 단말기 임의 개조 탐지 및 우회 대응, 프로그램 무결성 검증, 악성코드 탐지, 분실 도난 대책, 중요정보 평문 저장 금지, 거래내역 정보 제공 등의 대책을 기 운영중인 정책으로 유지

(1) 통신구간 암호화: SSL 인증서

- SSL 프로토콜을 사용한 거래 데이터 암호화 및 무결성 확인
- 암호화 프로토콜(SSL)을 이용하여 거래내역 노출과 거래내역 변조 방지
- X.509 v3 인증서를 이용한 암호화 키 분배
- 메시지 인증 코드 (MAC : Message Authentication Code)
- 암호화된 메시지 블록에 대한 메시지 인증 코드 부여

(2) 고객정보 웹/앱 내 저장 없음

- 기존 인터넷/스마트 뱅킹시스템에 적용된 보안정책이 적용되어 고객정보를 웹/앱내에 저장하고 있지 +
- 웹서버 내 개인정보 검출 솔루션 Server-i를 적용하여 서버내 개인정보 저장 여부를 감시.

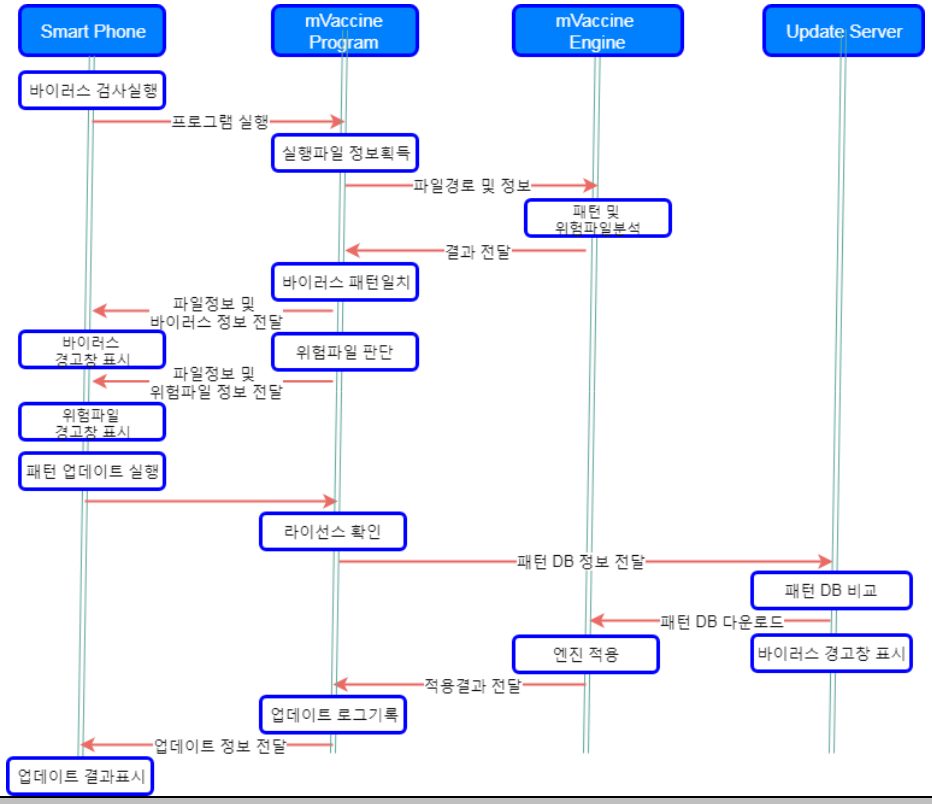
(3) 루팅 탐지

루팅 등 운영체제의 임의 개조 탐지를 위해 스틸리언 AppSuit을 통해 운영체제 임의 개조 여부를 탐지하여 차단

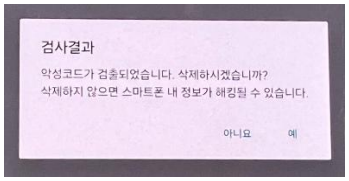
(4) 모바일백신/앱 무결성 검증/실시간 감시

모바일백신 (TouchEn mVaccine)
○ **개 요** 스마트폰 환경에서 바이러스 백신은 보다 안전한 사용자 환경을 제공함으로써 신뢰할 수 있는 금융거래서비스 구현하는 것을 보안 목적으로 하며, 스마트폰 환경에서의 바이러스 백신은 다음의 사항을 보안 목표로 한다. - 실시간 감시 - 바이러스 제거 및 삭제(악성코드 검사) - 업데이트

○ 동작절차

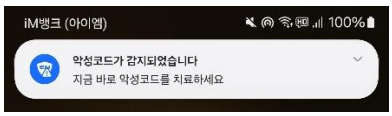


실시간 감시



실시간 감시 기능은 사용자 조작에 의하여 활성화 또는 비활성화 상태로 전환할 수 있으며, 실시간 감시 기능 활성화 시 실행되는 프로세스 에 대한 바이러스 감염 여부를 판단하는 프로세스가 동작함

악성코드 검사



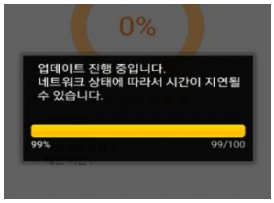
대상 파일이 바이러스 패턴정보와 일치하는 경우, 바이러스 경고창을 표시하고, 패턴의 변조 및 위험성이 감지되는 파일은 악성코드검사 결과창에 표시됨

결과 처리



발견된 악성앱에 대해서 제거여부를 사용자에게 확인 후 제거함. 제거과정은 실행프로그램에 대한 설치제거와 SD카드 등에서 발견된 파일에 대한 파일삭제로 구분됨

패턴 업데이트

	온라인서버로부터 암호화된 바이러스 패턴을 다운로드하고, 스마트폰 내 모바일 백신앱 데이터베이스에 업데이트함.

(5) 공동인증/금융인증 전자서명 보안적용(위즈베라Delfino G3)

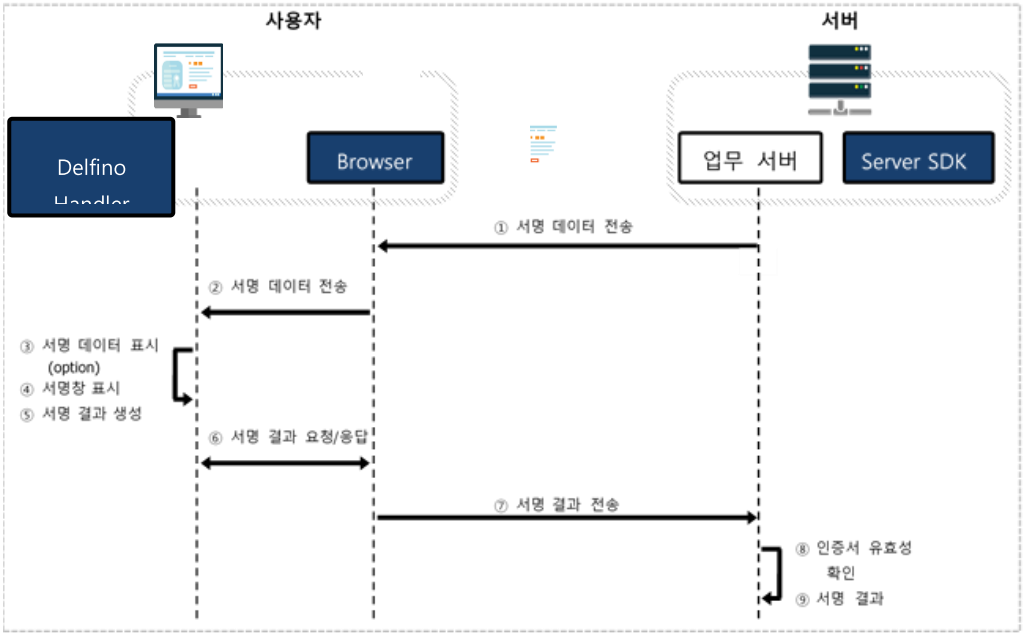
- 다양한 브라우저에서 서버와 데이터 송수신시 SSL기반의 암/복호화를 수행하며 PKI기반으로 사용자 인증 및 전자서명 등의 기능을 제공

제품 구조



- 제품은 Cross Domain Ajax 및 HTTPS 로컬 서버 기반으로 설계되었으며, 웹 브라우저와 로컬 데몬 서버간의 SSL 통신을 사용하여 데이터를 교환하는 구조

제품 상세 수행 과정



- Browser와 업무서버는 internet network 구간 통신이며 https를 사용
- Delfino Handler는 로컬 데몬 프로세스
- Browser와 Delfino Handler는 loopback 구간 통신이며 https 위에 다시 암호화 채널을 생성하여 사용

암호화 방식

① 로컬스토리지 암호화 방식

- 로컬스토리지에 저장된 키와 프로그램에 저장된 비밀키를 혼합하여 대칭키 생성
- 개인키 및 인증서는 PKCS12 형태로 암호화 되어있고, PKCS12는 다시 별도로 생성된 대칭키로 암호화하여 저장
- 로컬스토리지가 변경되는 경우 매번 로컬스토리지에 저장된 키는 새로 생성

② 로컬스토리지 암호화 알고리즘

- 대칭키 생성 알고리즘: SHA2
- PKCS12 알고리즘: pbeWithSHA, 3-KeyTripleDES-CBC
- 암호화 알고리즘: AES

가상키보드 인터페이스



가상 보안키보드 인터페이스

(6) 취약점 분석 대응

스마트폰 상에서 바이러스 방역에 대한 대책을 수립하였으나, 운영체제가 가진 취약점을 통한 부가적인 위협요소가 발생할 수 있음

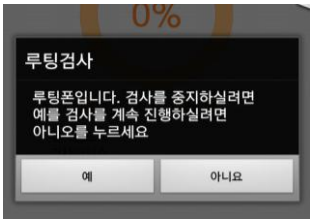
- 운영체제 취약점 분석

안드로이드 폰의 경우, Superusers Permission이라는 프로그램을 통하여 응용프로그램을 최고권한(Root권한)으로 실행(Rooting)하여 개인사용자 정보유출을 시도하게 된다.

- 취약점 대응전략

취약점 대응을 위하여 바이러스 방역의 기능에 취약점에 대응할 수 있는 분석 및 보안기능을 추가하여 사용자가 이를 인지할 수 있도록 하거나 사용 전 보안정책에 의하여 사전 차단할 수 있도록 한다.

- 운영체제 취약점 대응



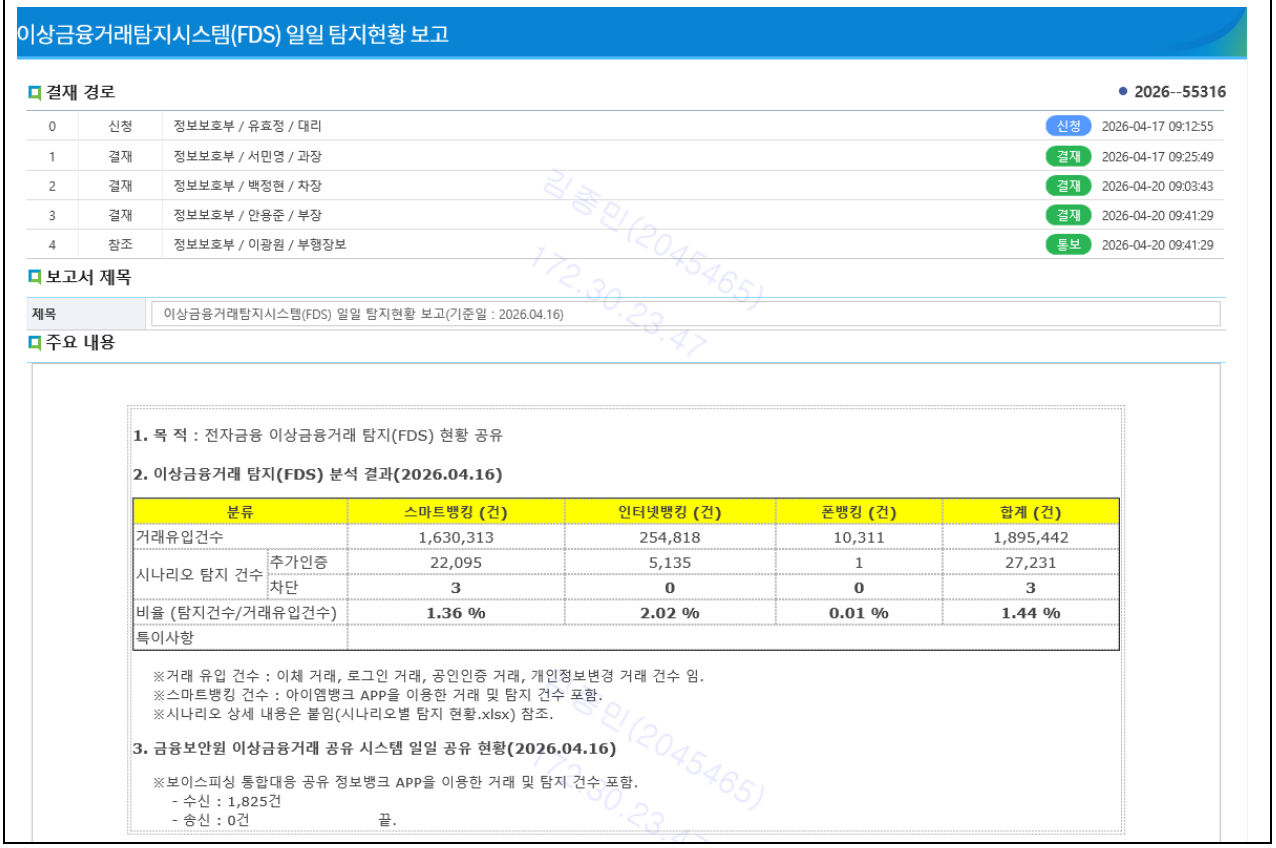
안드로이드폰의 경우, 루팅 여부를 판단하는 모듈을 통하여 루팅 적용된 안드로이드폰의 경우, 보안정책에 의해 프로그램 설치 및 사용을 차단할 수 있도록 한다.

5. 정보유출방지대책

○ 시스템 운영 및 개발직원의 개인별 사용자 계정 및 비밀번호 부여
○ 계정별로 정보시스템 접근권한을 부여하고, 부여된 접속 권한은 불필요시 권한 해지 및 계정 폐기
○ 보안도구(금융보안원 제공)를 이용한 시스템 취약성 분석 및 보안진단
○ 시스템 접속 차단(전산망 분리) 등 초동 조치
○ 물리적 망분리를 통한 인터넷 등 외부 연결 차단
○ 원격관리 금지
○ USB등 보조기억매체 통제 및 보안USB 사용
○ 문서보안시스템을 통한 내부문서 암호화
○ 테스트 시 테스트데이터를 통한 테스트 실시
○ Server-i를 통한 서버 내 개인정보 검출
○ 네트워크 접근통제시스템(NAC)을 통한 IP접근 제한
○ 무선침입방지시스템(WIPS)을 통한 WLAN 통제
○ 정보처리시스템 접근 기록 관리

6. 이상금융거래 방지대책

○ 이상금융거래탐지시스템(FDS)을 통해 거래 트랜잭션을 실시간 탐지하며, 전자금융사기 의심패턴 유형 따라 추가인증 절차(ARS) 요청 또는 이상거래 즉시 차단



이상금융거래탐지시스템(FDS) 일일 탐지현황 보고

결재 경로 ● 2026--55316

0	신청	정보보호부 / 유효정 / 대리	신청	2026-04-17 09:12:55
1	결재	정보보호부 / 서민영 / 과장	결재	2026-04-17 09:25:49
2	결재	정보보호부 / 백정현 / 차장	결재	2026-04-20 09:03:43
3	결재	정보보호부 / 안용준 / 부장	결재	2026-04-20 09:41:29
4	참조	정보보호부 / 이광원 / 부행장보	통보	2026-04-20 09:41:29

보고서 제목

제목	이상금융거래탐지시스템(FDS) 일일 탐지현황 보고(기준일 : 2026.04.16)

주요 내용

1. 목 적 : 전자금융 이상금융거래 탐지(FDS) 현황 공유

2. 이상금융거래 탐지(FDS) 분석 결과(2026.04.16)

분류		스마트뱅킹 (건)	인터넷뱅킹 (건)	폰뱅킹 (건)	합계 (건)
거래유입건수		1,630,313	254,818	10,311	1,895,442
시나리오 탐지 건수	추가인증	22,095	5,135	1	27,231
	차단	**3**	**0**	**0**	**3**
비율 (탐지건수/거래유입건수)		**1.36 %**	**2.02 %**	**0.01 %**	**1.44 %**
특이사항					

※거래 유입 건수 : 이체 거래, 로그인 거래, 공인인증 거래, 개인정보변경 거래 건수 임.
※스마트뱅킹 건수 : 아이엠뱅크 APP을 이용한 거래 및 탐지 건수 포함.
※시나리오 상세 내용은 붙임(시나리오별 탐지 현황.xlsx) 참조.

3. 금융보안원 이상금융거래 공유 시스템 일일 공유 현황(2026.04.16)

※보이스피싱 통합대응 공유 정보뱅크 APP을 이용한 거래 및 탐지 건수 포함.
- 수신 : 1,825건
- 송신 : 0건 끝.

7. 시스템 가용성 확보 및 비상대책

가. 업무지속성

○ 비상지원인력 지정

○ 위기대응매뉴얼 수립 운영

○ 전산시스템 이중화 구성

나. 비상사태 안전대책

○ 자료의 안정적인 관리를 위한 주기적인 백업체계 운영

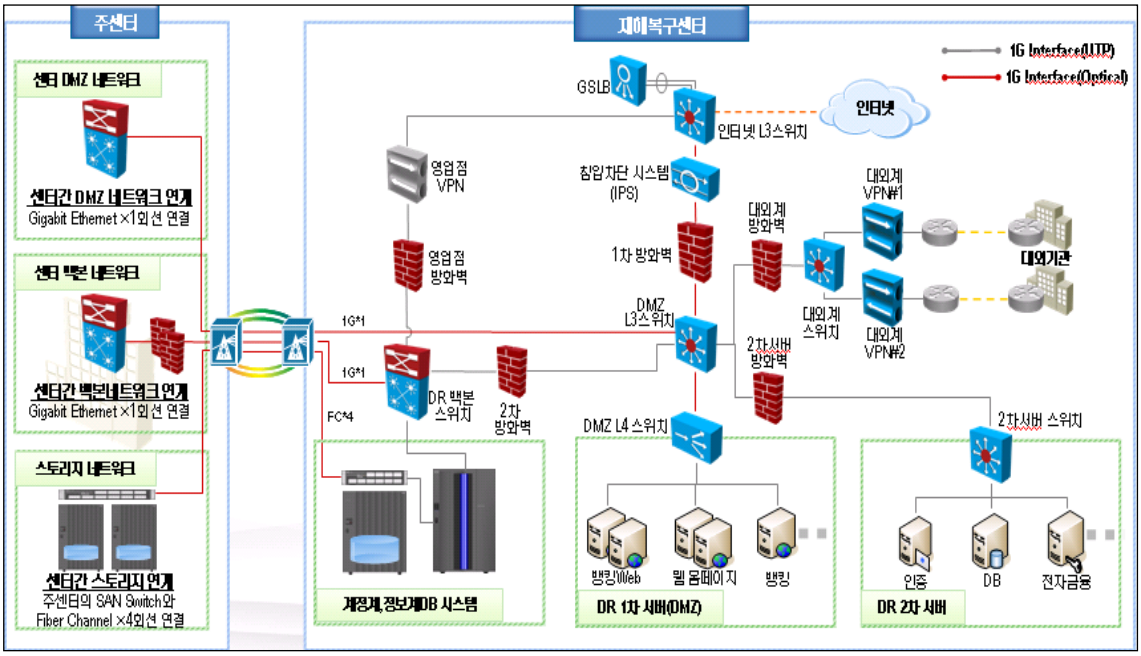
○ 업무지속성 확보를 위해 비상지원 인력 확보

- 주 업무 이외 보조업무 배정으로 업무의 이중화 인력 확보

○ 전산시스템 운영지침서, 사용자 매뉴얼 등 최신 상태 유지

다. 재해복구센터 운영

○ 재해복구센터 운영

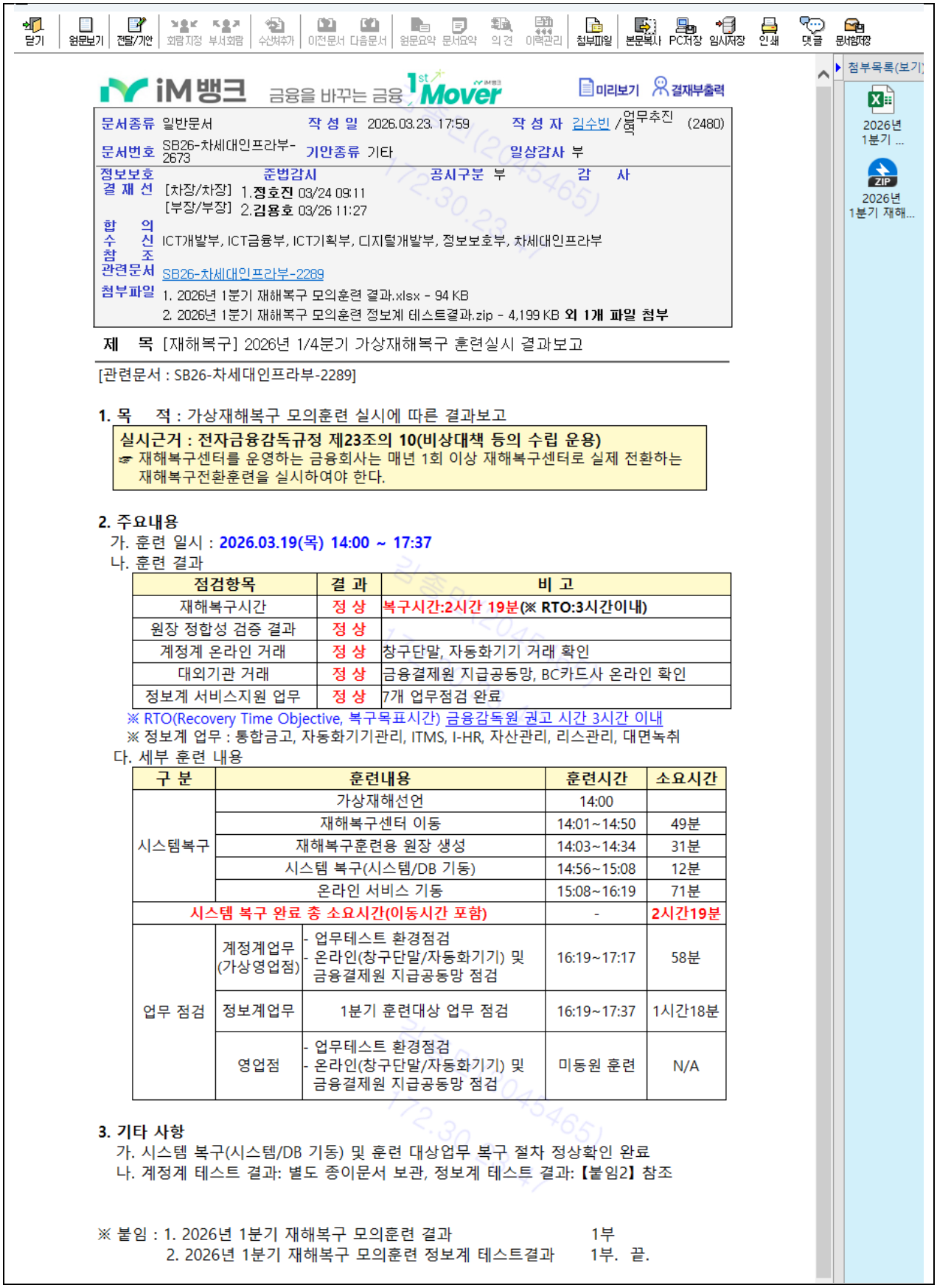


○ 정기적인 재해복구훈련 실시

(1) 목적

- 재해발생시 3시간 이내 신속한 복구를 위한 능력 배양
- 재해복구 시스템의 정합성 검증 및 복구 시간 단축
- 재해복구센터 제반 환경 점검

(2) 훈련 주기 : 연 4회 매 분기별 실시



닫기 | 원문보기 | 전달/기안 | 회람지정 | 부서회람 | 수신처추가 | 이전문서 | 다음문서 | 원문요약 | 문서요약 | 의견 | 이력관리 | 첨부파일 | 본문복사 | PC저장 | 임시저장 | 인쇄 | 댓글 | 문서캡쳐

iM뱅크 금융을 바꾸는 금융 1st Mover

미리보기 결재부출력

문서종류	일반문서	작 성 일	2026.03.23. 17:59	작 성 자	김수빈 / 업무추진 (2480)
문서번호	SB26-차세대인프라부-2673	기안종류	기타	일상감사	부
정보보호	준법감시	공시구분	부	감 사	
결 재 선	[차장/차장] 1.정호진 03/24 09:11 [부장/부장] 2.김용호 03/26 11:27				
합 의					
수 신 참 조	ICT개발부, ICT금융부, ICT기획부, 디지털개발부, 정보보호부, 차세대인프라부				
관련문서	SB26-차세대인프라부-2289				
첨부파일	1. 2026년 1분기 재해복구 모의훈련 결과.xlsx - 94 KB 2. 2026년 1분기 재해복구 모의훈련 정보계 테스트결과.zip - 4,199 KB 외 1개 파일 첨부				

첨부목록(보기)

2026년 1분기 ...

2026년 1분기 재해...

제 목 [재해복구] 2026년 1/4분기 가상재해복구 훈련실시 결과보고

[관련문서 : SB26-차세대인프라부-2289]

1. 목 적 : 가상재해복구 모의훈련 실시에 따른 결과보고

실시근거 : 전자금융감독규정 제23조의 10(비상대책 등의 수립 운용)
☞ 재해복구센터를 운영하는 금융회사는 매년 1회 이상 재해복구센터로 실제 전환하는 재해복구전환훈련을 실시하여야 한다.

2. 주요내용

가. 훈련 일시 : **2026.03.19(목) 14:00 ~ 17:37**

나. 훈련 결과

점검항목	결 과	비 고
재해복구시간	정 상	복구시간:2시간 19분(※ RTO:3시간이내)
원장 정합성 검증 결과	정 상	
계정계 온라인 거래	정 상	창구단말, 자동화기기 거래 확인
대외기관 거래	정 상	금융결제원 지급공동망, BC카드사 온라인 확인
정보계 서비스지원 업무	정 상	7개 업무점검 완료

※ RTO(Recovery Time Objective, 복구목표시간) 금융감독원 권고 시간 3시간 이내
※ 정보계 업무 : 통합금고, 자동화기기관리, ITMS, I-HR, 자산관리, 리스관리, 대면녹취

다. 세부 훈련 내용

구 분	훈련내용		훈련시간	소요시간
시스템복구	가상재해선언		14:00	
	재해복구센터 이동		14:01~14:50	49분
	재해복구훈련용 원장 생성		14:03~14:34	31분
	시스템 복구(시스템/DB 기동)		14:56~15:08	12분
	온라인 서비스 기동		15:08~16:19	71분
시스템 복구 완료 총 소요시간(이동시간 포함)			-	2시간19분
업무 점검	계정계업무 (가상영업점)	- 업무테스트 환경점검 - 온라인(창구단말/자동화기기) 및 금융결제원 지급공동망 점검	16:19~17:17	58분
	정보계업무	1분기 훈련대상 업무 점검	16:19~17:37	1시간18분
	영업점	- 업무테스트 환경점검 - 온라인(창구단말/자동화기기) 및 금융결제원 지급공동망 점검	미동원 훈련	N/A

3. 기타 사항

가. 시스템 복구(시스템/DB 기동) 및 훈련 대상업무 복구 절차 정상확인 완료

나. 계정계 테스트 결과: 별도 종이문서 보관, 정보계 테스트 결과: 【붙임2】 참조

※ 붙임 : 1. 2026년 1분기 재해복구 모의훈련 결과 1부
2. 2026년 1분기 재해복구 모의훈련 정보계 테스트결과 1부. 끝.

8. 시스템 설치장소에 대한 물리적 접근통제

가. 보호구역 설정

○ 정보통신시설 및 장소에 대한 보호구역 설정 및 관리

나. 전산센터 물리적 접근통제(출입통제)

○ 전산장비는 당행 전산센터 내에 위치하고, 통제구역 내 비인가자 출입 금지

○ 출입통제(카드키, 출입인가자 명부비치, 경비요원 상주, CCTV 등)

○ 전산센터 환경통제(내진설계, 연기·온도 감지, 화재경보, UPS 등)

다. 전산센터 내 전산자료 및 장비 반·출입 통제

○ 장비의 반·출입은 사전 신고에 의해 가능

○ USB 저장장치 및 노트북 등 비인가저장매체의 반출입 금지(필요시 사전신고)

라. 무선통신망 설치 제한

○ 전산센터 등 주요시설에 무선통신망 사용 통제

○ 무선침입방지시스템(WIPS)을 통한 통제 실시

○ 업무상 필요 시 정보보호최고책임자(CISO) 승인 후 사용

9. 취약점 점검 실시

가. 목적 및 방법

금융인증서 서비스에 대한 보안 취약점과 개선사항을 파악하여 이에 대한 적절한 대책을 수립하기 위한 것으로, 모의해킹을 통해 OWASP Top 10 취약점 항목 및 국정원 8대 취약점 항목에 대한 점검 수행을 진행함.

애플리케이션의 취약점 및 통제 공백 내용을 파악하기 위해 악의적인 해커나 크래커들이 사용하는 해킹 기법들을 이용하여, 지정된 대상 시스템에 대해 모의 침투 테스트를 시도하여 진행

나. 점검방법 : ㈜ SK쉴더스 (☞정보보호전문서비스기업)을 통한 점검

다. 점검결과 :

iM뱅크 금융을 바꾸는 금융 1st Mover 미리보기 결재부출력

문서종류	일반문서	작 성 일	2026.04.10. 17:30	작 성 자	이경민 /대리(6443)
문서번호	SB26-정보보호부-2775	기안종류	기타	일상감사	부
정보보호	준법감시	공시구분	부	감 사	
결 재 선	[차장/차장] 1.백정현 04/13 10:45 [부장/부장] 2.代이의경 04/13 10:47				
합 의					
수 신	디지털개발부				
참 조	노종훈(디지털개발부)				
첨부파일					

제 목 취약점 분석·평가 결과 안내 [iM뱅크(APP)-AI 사진송금 서비스)]

[관련문서 : 정보보호포털 - 2026--55023 의뢰서]

1. 목 적 : "iM뱅크(APP)-AI 사진송금 서비스" 취약점 분석·평가(이하, 점검) 결과 안내

2. 주요내용

가. 점검결과

○ 발견된 취약점 미존재

분 류	점검대상	점검 항목수	발견된 취약점	조치된 취약점	잔여 취약점
MOBILE	iM뱅크(APP)	56	0	0	0

※ 점검대상 담당자에게 취약점 점검 결과보고서 별도 송부

나. 점검수행 : 본점검 - SK쉴더스

다. 점검기준 : 전자금융기반시설 보안 취약점 평가 기준 적용

라. 점검일자 : 본점검 - 2026.04.06 ~ 04.10(5일간)

※ 정보보호포털의 경우 조치 여부 확인 후 처리 완료 예정 (의뢰서 "2026--55023")

3. 협조사항

추가 취약점이 발생되지 않도록 지속적으로 프로그램 관리에 만전을 기하여 주시기 바랍니다. 끝.

접수번호 : **접수일자 :**

끝.